

Phase 5.2.2 JWT Security Hardening Report

Appliance Target: RCS CyberTrack Core Management | **Status:** 100% PASSED (120/120 Tests)

EXECUTIVE SUMMARY:

Phase 5.2.2 JWT Security Hardening has been successfully implemented across RCS CyberTrack's authentication engine. All access tokens now enforce 7 mandatory claims (sub, exp, iat, jti, iss, aud, type) with algorithm locking strictly fixed to HS256. The decoder enforces signature, expiration, issuer, audience, and token-type separation while rejecting algorithm confusion and tampered payloads. The full test suite passed with **120 passed tests** (19 new dedicated Phase 5.2.2 JWT security tests).

1. Implemented JWT Protections

- **7-Claim Standard JWT Tokens:** Token generation in `create_access_token` populates sub, exp, iat, jti, iss, aud, and type="access".
- **Cryptographic JTI Uniqueness:** Generates a fresh `uuid.uuid4().hex` identifier for every token, providing unique token identity for Phase 5.2.3 revocation.
- **Strict Algorithm Locking (`HS256`):** Enforces `algorithms=["HS256"]`. Explicitly rejects none, RS256, HS384, HS512, and algorithm confusion attempts.
- **Issuer & Audience Verification:** Validates configured identity (CYBERTRACK_JWT_ISSUER & CYBERTRACK_JWT_AUDIENCE). Rejects tokens with mismatched or missing issuer/audience.
- **IAT & Future Timestamp Validation:** Enforces `verify_iat=True` and rejects tokens with issued-at timestamps set in the future beyond allowed clock skew (CYBERTRACK_JWT_LEEWAY_SECONDS).
- **Token Purpose Separation:** Requires type="access" claim, preventing cross-purpose token misuse (e.g. rejecting refresh or API tokens on access endpoints).

2. Test Verification Results

Test Suite Module	Status	Test Scope / Coverage
test_api.py	PASSED	API authentication, system status & RBAC rules
test_firewall.py	PASSED	Firewall rule management & compilation
test_network.py	PASSED	Network interface & routing engine
test_phase4b_api.py	PASSED	Security alert & audit log endpoints
test_phase51_rbac_users.py	PASSED	User management & lockout safeguards
test_phase52_config_engine.py	PASSED	Configuration staging & commit state machine
test_phase53_nftables.py	PASSED	nftables compiler & process isolation
test_phase54_hardening.py	PASSED	Phase 5.1 production security boundaries
test_phase521_secret_bootstrap.py	PASSED	Phase 5.2.1 secret & bootstrap hardening
test_phase522_jwt_security.py	PASSED	Phase 5.2.2 JWT claims, algorithm lock & verification
TOTAL SUITE RESULT	120 PASSED	100% Pass Rate (120 Passed in 14.53s)

3. Modified Repository Files Manifest

File Path	Status	Description of Changes
.env.example	Modified	Added CYBERTRACK_JWT_ISSUER & CYBERTRACK_JWT_AUDIENCE
management/auth/auth.py	Modified	7-claim JWT creation & strict decode_access_token engine
tests/test_phase522_jwt_security.py	CREATED	19 new JWT claim, signature & algorithm security tests

4. Verification Conclusion

Phase 5.2.2 JWT Security Hardening is complete, verified, and regression-free. The authentication system is prepared for Phase 5.2.3 Token Revocation & Logout.